

AN TOÀN THÔNG TIN (INSE330380)

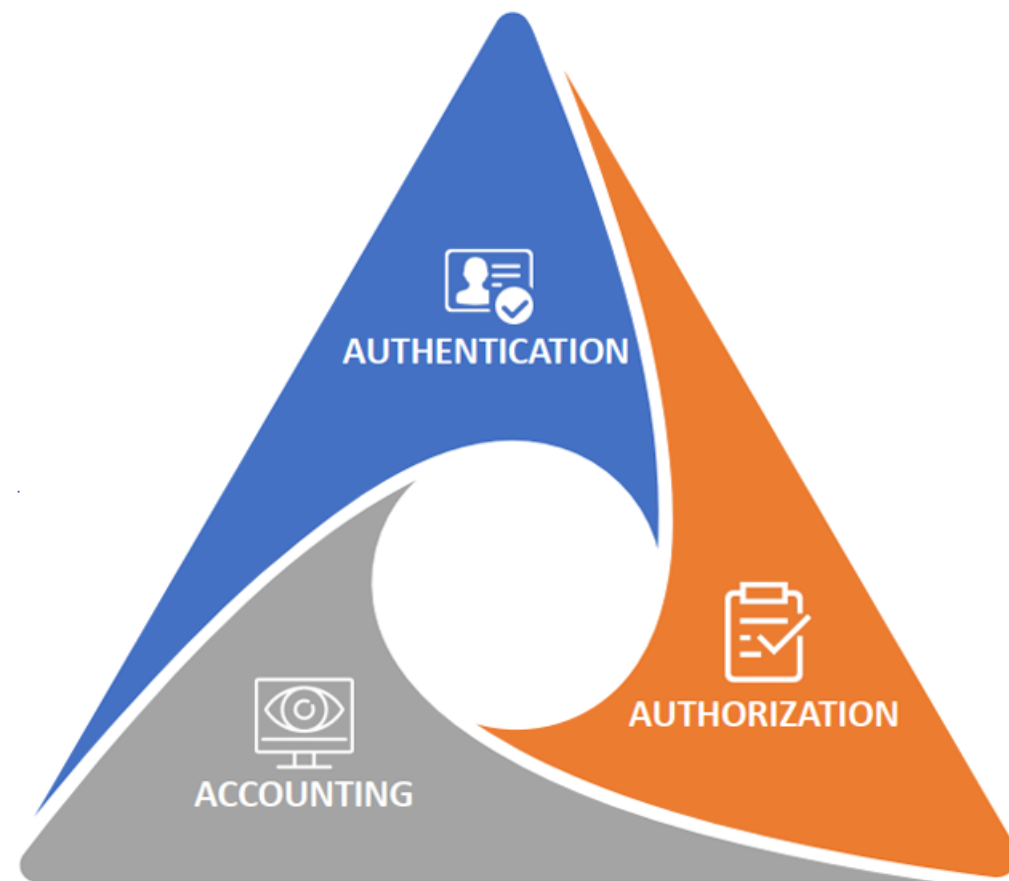
CHƯƠNG III XÁC THỰC (Authentication)

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu bài học
- ☐ Authentication Goals, mô hình xác thực
- ☐ Sự phát triển của công nghệ xác thực
- ☐ Triển khai xác thực mật khẩu, Hash functions
- ☐ Tấn công vào xác thực bằng mật khẩu. Password Cracking Tools
- ☐ Bảo mật xác thực bằng mật khẩu
- ☐ Các phương pháp xác thực khác: Token, sinh trắc học, đa yếu tố (MFA), người dùng từ xa, không mật khẩu.
- ☐ Tóm tắt.

Thế giới an ninh mạng rất rộng lớn với nhiều thành phần phức tạp phối hợp với nhau để đảm bảo sự an toàn và tính toàn vẹn của hệ thống kỹ thuật số.

- ❑ Framework AAA là một mô hình thiết kế bảo mật cung cấp cấu trúc rõ ràng để quản lý quyền truy cập mạng.
- ❑ Đây là một phần quan trọng của bất kỳ chiến lược an ninh mạng mạnh mẽ nào, cung cấp các công cụ cần thiết để kiểm soát và giám sát việc truy cập mạng.

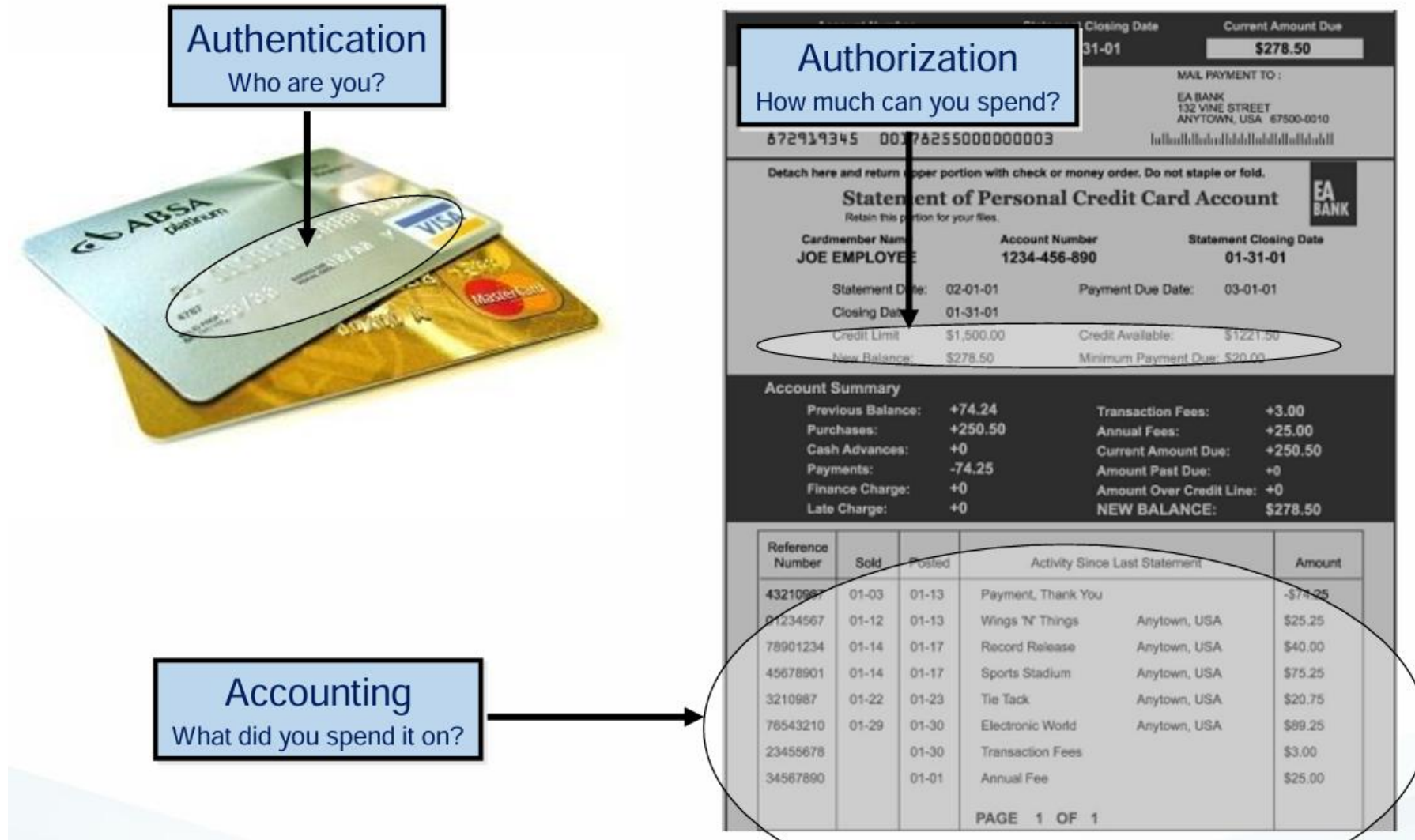


- ❑ AAA đề cập đến một tập hợp các quy trình và dịch vụ được sử dụng để kiểm soát quyền truy cập vào tài nguyên mạng và quản lý các tương tác của người dùng trong môi trường mạng.
- ❑ Mỗi thành phần của AAA đóng một vai trò cụ thể trong việc đảm bảo tính bảo mật, quản lý và trách nhiệm giải trình các hoạt động của mạng.



- ❑ **Authentication- Xác thực:** Xác minh rằng thông tin xác thực của người dùng hoặc thực thể hệ thống khác là hợp lệ.
- ❑ **Authorization- Ủy quyền:** Việc cấp quyền hoặc sự cho phép cho một thực thể hệ thống truy cập tài nguyên hệ thống. Chức năng này xác định ai được tin cậy cho một mục đích nhất định.
- ❑ **Accounting– kiểm toán:** liên quan đến việc theo dõi và ghi lại hoạt động của người dùng. Đánh giá và kiểm tra độc lập các hồ sơ và hoạt động của hệ thống nhằm kiểm tra tính đầy đủ của các biện pháp kiểm soát hệ thống, đảm bảo tuân thủ chính sách bảo mật đã thiết lập.

Ví dụ:

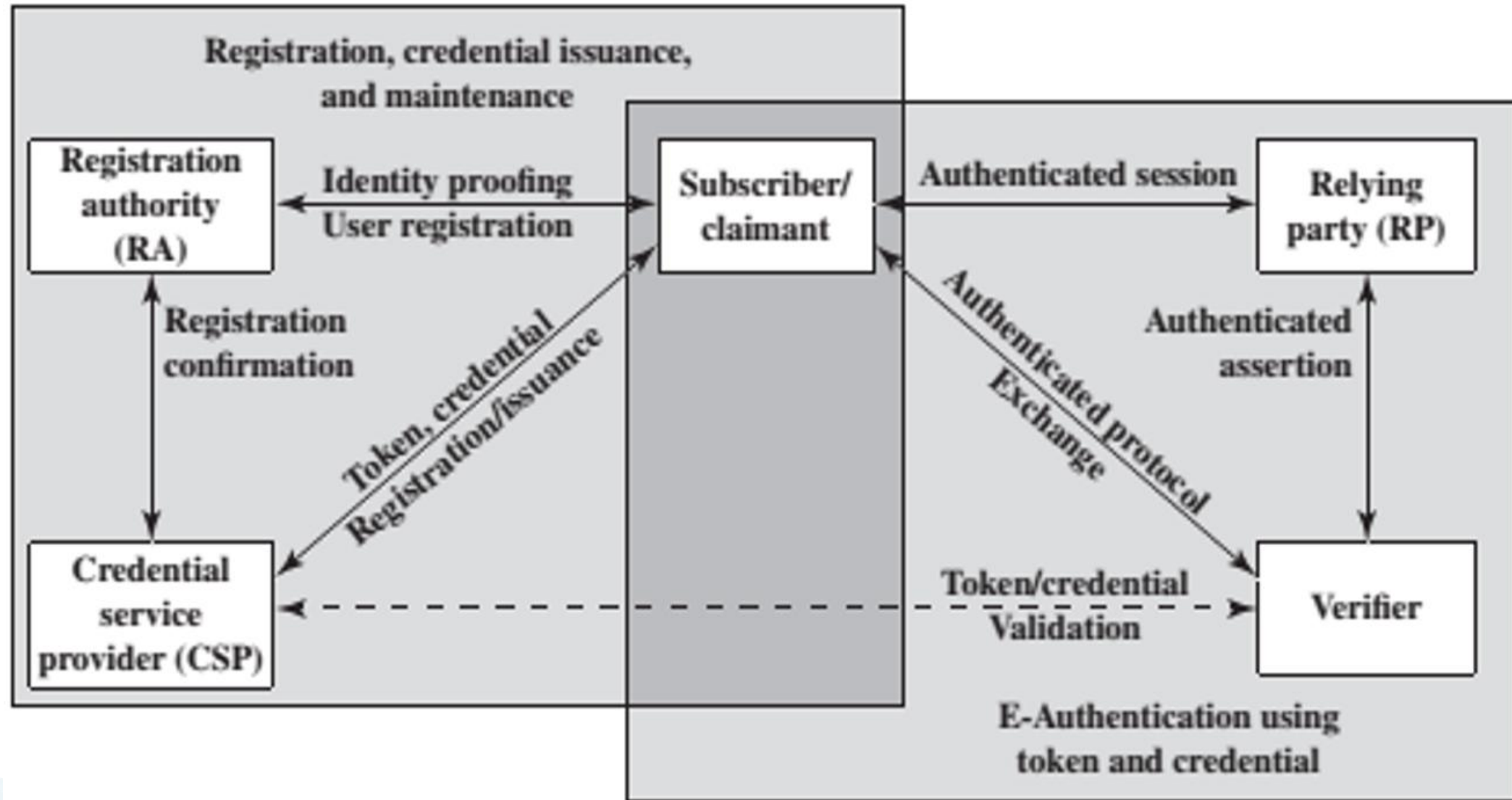


- ☐ **Khả dụng-Availability:** khi thông tin xác thực chính xác được xuất trình, tài nguyên sẽ được cung cấp cho bộ xử lý (thay mặt cho người dùng).
- ☐ **Không có dương tính giả (No false positives / False Accept)** Dương tính giả xảy ra khi người/tiến trình không hợp lệ nhưng hệ thống lại chấp nhận xác thực và cấp quyền truy cập. Đây là lỗi nghiêm trọng về bảo mật, vì dẫn đến truy cập trái phép.
- ☐ **Không có âm tính giả (No false negatives / False Reject)** Âm tính giả xảy ra khi người/tiến trình hợp lệ nhưng hệ thống lại từ chối xác thực và không cho truy cập. Đây là lỗi ảnh hưởng đến khả dụng và trải nghiệm người dùng.

Kẻ tấn công đoán chính xác mật khẩu của Alice và đăng nhập với tư cách là cô ấy.

Đây là trường hợp gì...

- A. False negative
- B. True positive
- C. False positive
- D. True negative





- ❑ 1961: Mật khẩu (Fernando J. Corbató, MIT): lưu trữ mật khẩu dạng văn bản gốc
- ❑ Cuối những năm 1960: mã hóa mật khẩu (Robert Morris, Bell Labs.) : hàm băm mật khẩu - cực kỳ khó crack. Tin tặc có thể xây dựng máy quét mật khẩu.
- ❑ Những năm 1980: Mật khẩu động. Mật khẩu thay đổi dựa trên các yếu tố như thời gian, địa điểm hoặc cập nhật mật khẩu vật lý.
- ❑ Hai giao thức mật khẩu động: OTP dựa trên thời gian (TOTP) và HMAC.
- ❑ Cuối những năm 1990: Cơ sở hạ tầng khóa công khai Giao thức bảo mật lớp vận chuyển – TLS. Cuối 1990s, Taher Elgamal - kỹ sư tại Netscape - đã phát triển giao thức SSL



- ❑ Những năm 2000: xác thực đa yếu tố và đăng nhập một lần
- ❑ Những năm 2010: Sinh trắc học. Năm 2011, Motorola ATRIX Android là thiết bị di động đầu tiên có máy quét dấu vân tay. Apple đang đi sau thời đại với công nghệ Touch ID. 2017, Apple đã có công nghệ FaceID. Công nghệ xác thực sinh trắc học mang đến mức độ bảo mật và tiện lợi cao hơn
- ❑ Thập kỷ 2020: Xác thực không mật khẩu. Sử dụng khóa xác thực (khóa vật lý, ứng dụng khóa ảo trên smartphone) sau đó kích hoạt khóa sinh trắc học để xác thực. Xu hướng công nghệ lớn, tất yếu của tương lai bởi lợi ích vượt trội trong việc nâng cao hiệu quả bảo mật, điển hình là Apple, Microsoft, Samsung, Amazon,...

- ❑ Something the Individual knows– cá nhân biết: mật khẩu, số nhận dạng cá nhân (PIN) trả lời các câu hỏi
- ❑ Something the Individual possesses- cá nhân sở hữu:
 - Thẻ từ điện tử, thẻ thông minh và chìa khóa vật lý.
 - Đây được gọi là Token
- ❑ Something the individual is (static biometrics): Nhận dạng bằng vân tay, võng mạc và khuôn mặt
- ❑ Something the individual is (dynamic biometrics): Nhận dạng bằng mẫu giọng nói, đặc điểm chữ viết và nhịp gõ

Xác thực: Xác minh quyền truy cập của người dùng vào hệ điều hành / ứng dụng

☐ **Xác thực vật lý:**

- Cho phép nhập vật lý, Thẻ từ và các phương pháp sinh trắc học

☐ **RADIUS:** được các thiết bị mạng sử dụng để cung cấp cơ chế xác thực tập trung

- RADIUS cung cấp: Xác thực, Ủy quyền, Kế toán

- ❑ Mã số kỹ thuật số (mã thông báo bảo mật):
 - Thiết bị điện tử nhỏ. Hiển thị một số duy nhất cho chủ sở hữu token; mật khẩu một lần
- ❑ Thẻ kỹ thuật số: Còn được gọi là thẻ an ninh hoặc thẻ thông minh
 - Tương tự như thẻ tín dụng; sử dụng một mạch điện tử thay vì một dải từ
 - Lưu trữ thông tin nhận dạng người dùng
- ❑ Kerberos: Phát triển bởi MIT. Sử dụng vé cho mục đích xác thực

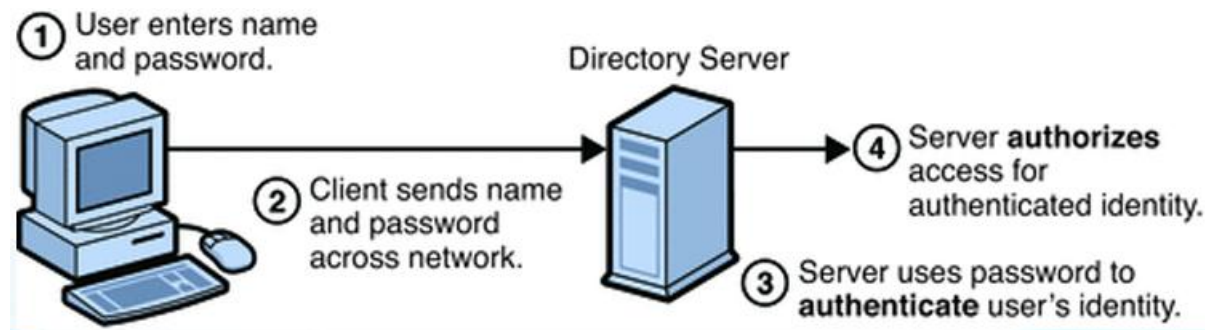
❑ Giao thức Truy cập Thư mục Thấp (LDAP- Lightweight Directory Access Protocol):

- Được phát triển bởi Đại học Michigan
- Một trung tâm CSDL tập trung: Người dùng, Mật khẩu, Danh bạ điện thoại, Khóa bảo mật
- Hiệu quả để đọc nhưng không phù hợp với thông tin thường xuyên thay đổi

❑ Quản lý LAN NT (NTLM):

- Được phát triển và sử dụng bởi Microsoft
- Sử dụng một giao thức xác thực / đáp ứng

- ❑ Là quá trình giành quyền truy cập vào các tài nguyên mà người ta có quyền sử dụng với thông tin xác thực người dùng và mật khẩu.
- ❑ Đây là phương pháp được sử dụng rộng rãi vì tính đơn giản và chi phí thấp.
- ❑ Tuy nhiên nó có những lỗ hổng có thể dẫn đến các cuộc tấn công và vi phạm. Do đó, các tổ chức phải áp dụng xác thực an toàn và triển khai các biện pháp thực hành mật khẩu tốt nhất để giảm thiểu những rủi ro này



❑ Cuộc tấn công từ điển offline (Brute force):

- Một hacker truy cập vào tệp mật khẩu hệ thống.
- So sánh mật khẩu hashes với các hashes của các mật khẩu thường được sử dụng.

❑ Tấn công tài khoản cụ thể:

- Người tấn công nhắm đến một tài khoản cụ thể & đưa ra dự đoán mật khẩu cho đến khi tìm ra mật khẩu chính xác.

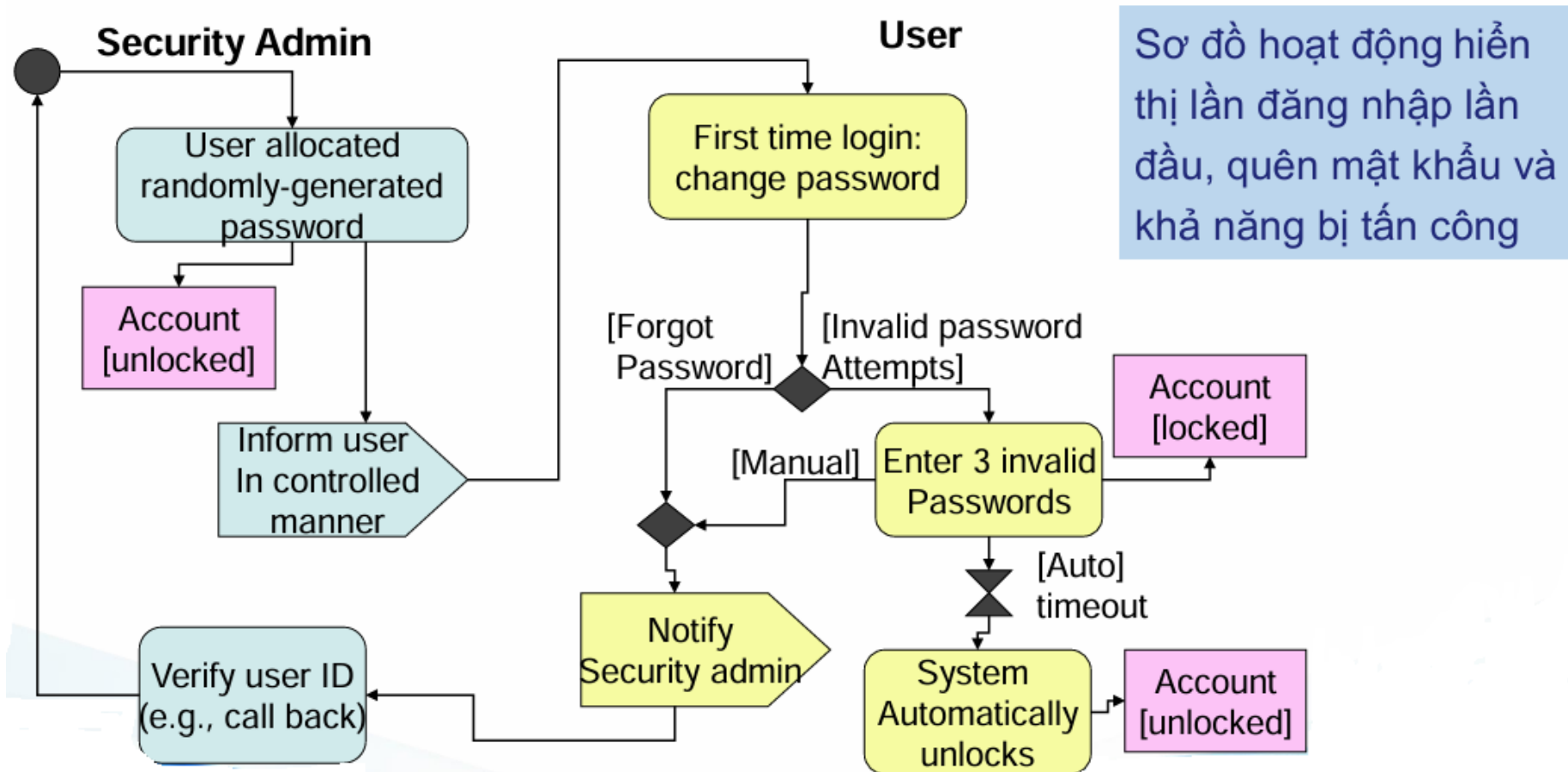
❑ Tấn công mật khẩu phổ biến / Chống lại người dùng đơn:

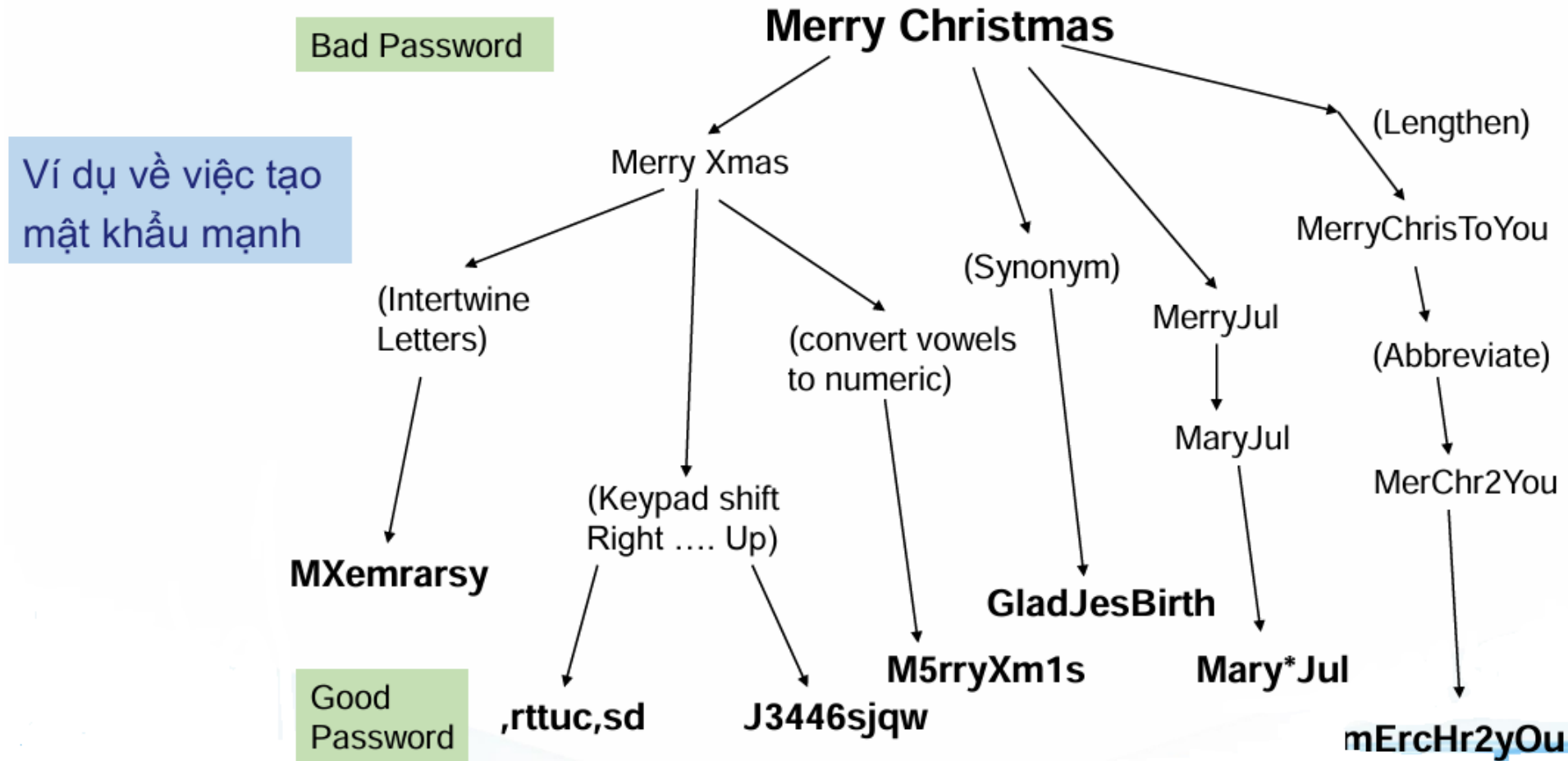
- Kẻ tấn công chọn một mật khẩu phổ biến và thử nó.
- Người tấn công cố gắng tìm hiểu kiến thức về chủ tài khoản và chính sách mật khẩu hệ thống và sử dụng kiến thức đó để đoán

- ☐ **Cướp máy trạm:** Kẻ tấn công đợi cho đến khi một máy trạm đăng nhập không cần giám sát.
- ☐ **Khai thác lỗi của người sử dụng:** Người dùng có nhiều khả năng viết nó mật khẩu, bởi vì nó là khó nhớ.
- ☐ **Khai thác sử dụng nhiều mật khẩu:** Mật khẩu tương tự cho nhiều ứng dụng
- ☐ **Theo dõi điện tử:** Nếu một mật khẩu được truyền thông qua mạng để đăng nhập vào một hệ thống từ xa, nó dễ bị nghe trộm

Để tăng cường tính bảo mật của hệ thống xác thực dựa trên mật khẩu, điều cần thiết là phải triển khai các chính sách mật khẩu mạnh mẽ và cập nhật thường xuyên đồng thời tích hợp các lớp bảo mật bổ sung.

- ☐ Thực thi chính sách mật khẩu mạnh, thay đổi mật khẩu thường xuyên
- ☐ Lưu trữ an toàn thông tin xác thực người dùng
- ☐ Thực hiện băm mật khẩu
- ☐ Quản lý người dùng quay lại
- ☐ Xác thực đa yếu tố (MFA)





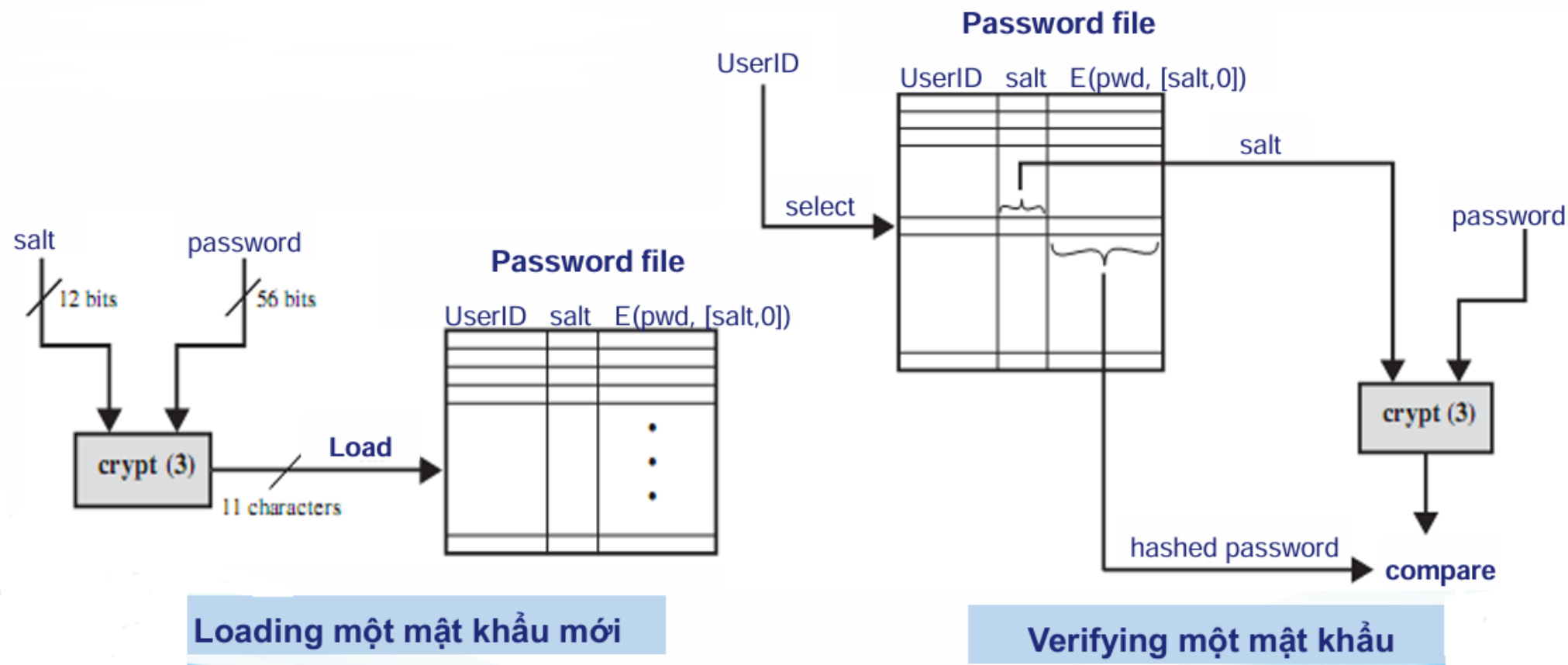
☐ Lưu trữ an toàn thông tin xác thực người dùng

- Lưu trữ danh sách mật khẩu, một mật khẩu cho mỗi người dùng trong tệp hệ thống.
- Tệp chỉ có thể đọc được bằng tài khoản root/admin
- Nếu bảo mật bị vi phạm, mật khẩu sẽ bị lộ cho kẻ tấn công.

☐ Không lưu trữ mật khẩu mà lưu trữ thứ gì đó có nguồn gốc từ chúng

- Sử dụng hàm băm một chiều và lưu trữ kết quả
- Tệp mật khẩu chỉ có thể đọc được đối với root/admin

Lưu trữ an toàn thông tin xác thực người dùng trong UNIX



- ❑ Thực hiện băm mật khẩu (hash).
 - Thuật toán mã hóa – hàm một chiều
 - Một số hàm thuật toán hash như: MD5, SHA-512,....
- ❑ Tấn công có thể xây dựng các chương trình để đoán mật khẩu (Brute force).
 - Để chống lại điều này, dùng mật khẩu động.

❑ Có 2 giao thức mật khẩu động:

- TOTP= Time-based OTP - tính duy nhất của OTP được tạo dựa trên thời gian hiện tại.
- HOTP là OTP dựa trên HMAC, được tạo từ khóa bí mật chia sẻ và bộ đếm tăng dần; mỗi giá trị counter tạo ra một OTP khác nhau.”

❑ Đặc điểm

- Những mật khẩu này thay đổi dựa trên các biến số, như vị trí, thời gian hoặc cập nhật mật khẩu vật lý (như FOB).
- Loại bỏ mọi rủi ro và giải quyết vấn đề gây ra khi người dùng có cùng mật khẩu ở nhiều nơi.
- Kết hợp với mật khẩu thông thường như một hình thức xác thực 2 yếu tố là rất phổ biến.
- Xác thực đa yếu tố (MFA- Multi-factor authentication)

- ❑ Hạ tầng khóa công khai (PKI - Public Key Infrastructure) là một cơ chế để cho một bên thứ 3 cung cấp và xác thực định danh các bên tham gia vào quá trình trao đổi thông tin.
- ❑ Cơ chế này cũng cho phép gán cho mỗi người sử dụng trong hệ thống một cặp khóa công khai/khóa bí mật.



Hạ tầng khóa công khai (PKI - Public Key Infrastructure). Mỗi PKI phải bao gồm:

- ☐ Cơ quan cấp chứng chỉ (Certificate authority - CA) = Người phát hành chứng thư số (bao gồm cả việc ký).
- ☐ Cơ quan đăng ký (Registration authority) = Người xác minh danh tính yêu cầu chứng chỉ số
- ☐ Thư mục trung tâm(Central directory) = Nơi lưu trữ khóa.
- ☐ Hệ thống quản lý chứng chỉ = Cấu trúc cho các hoạt động, chẳng hạn như truy cập các chứng chỉ được lưu trữ.
- ☐ Chính sách chứng chỉ = Tuyên bố về yêu cầu PKI.

Token là mã do máy tính tạo ra, hoạt động như chữ ký được mã hóa kỹ thuật số xác thực danh tính của người dùng để truy cập bất kỳ trang web hoặc mạng.



Token được phân thành hai loại:

- ❑ **Authenticator token.** Token dùng cho xác thực: sử dụng 1 thiết bị hữu hình để lưu trữ thông tin của người dùng, khóa bí mật.
 - Token cứng: sử dụng thẻ thông minh và USB có quyền truy cập vào mạng, văn phòng
 - Token mềm: sử dụng thiết bị di động hoặc máy tính để gửi mã được mã hóa (như OTP) qua ứng dụng hoặc SMS được ủy quyền.

Token được phân thành hai loại:

❑ Access/Session token.

- JWT: token dạng JSON, thường được ký để server kiểm tra tính toàn vẹn và hạn dùng
- Opaque token: chuỗi ngẫu nhiên, cần server tra cứu/introspection

Xác thực dựa trên Token hoạt động thông qua quy trình bốn bước:

1. Yêu cầu: đăng nhập với Thông tin xác thực bao gồm tên người dùng, mật khẩu, thẻ thông minh hoặc sinh trắc học
2. Xác minh: Thông tin đăng nhập được gửi đến máy chủ xác thực để xác minh người dùng hợp lệ. Nếu đúng, máy chủ sẽ tạo khóa kỹ thuật số bí mật cho người dùng dưới dạng mã.

Xác thực dựa trên Token hoạt động thông qua quy trình bốn bước:

3. **Xác thực Token:** Người dùng nhận mã token và nhập mã đó để truy cập vào mạng. Mã token có hiệu lực trong 30-60 giây và có thể yêu cầu mã token Refresh từ máy chủ xác thực.
4. **Lưu trữ:** Sau khi máy chủ tài nguyên xác thực mã token và cấp quyền truy cập cho người dùng, máy chủ tài nguyên sẽ lưu mã token trong CSDL trong thời gian phiên xác định. Thời gian phiên là khác nhau đối với mỗi trang web hoặc ứng dụng. Ví dụ: các ứng dụng Ngân hàng có thời gian phiên ngắn nhất chỉ khoảng vài phút.

Sơ đồ hoạt động của Xác thực dựa vào Token (Access token)



- ❑ Mã Token có thời hạn: mã Token sẽ bị hủy khi người dùng kết thúc phiên duyệt web, đảm bảo rằng tài khoản được bảo vệ và không có nguy cơ bị tấn công mạng.
- ❑ Mã Token được mã hóa và do máy tạo: Mỗi mã Token là duy nhất cho phiên của người dùng và được bảo vệ bằng thuật toán, đảm bảo máy chủ có thể xác định mã thông báo đã bị giả mạo và chặn nó.

- ❑ Mã Token hợp lý hóa quy trình đăng nhập: Mã Token người dùng không phải nhập lại thông tin đăng nhập mỗi khi họ truy cập trang web. => nhanh hơn và thân thiện hơn với người dùng.
- ❑ Token bổ sung rào cản ngăn chặn tin tặc: Rào cản 2FA bổ sung thêm một lớp bảo mật, ngăn chặn tin tặc truy cập vào tài khoản ngay cả khi chúng đánh cắp thông tin đăng nhập của người dùng.

- ❑ Xác thực sinh trắc học là một quy trình bảo mật dựa vào các đặc điểm sinh học độc đáo của các cá nhân để xác minh họ là chính mình.
- ❑ Sinh trắc học dạng tĩnh: Nhận dạng bằng vân tay, võng mạc và khuôn mặt
- ❑ Sinh trắc học dạng động: Nhận dạng bằng giọng nói, đặc điểm chữ viết và nhịp gõ
- ❑ Ưu điểm hệ thống sinh trắc học:
 - Tránh việc ghi nhớ mật khẩu dài, mất token
 - Có tính duy nhất và không thể sao chép

Mô hình xác thực sinh trắc học đơn nhân tố bao gồm hai giai đoạn:

❑ Đăng ký (Enrollment):

- Lấy mẫu tham chiếu và quyết định tới việc xác thực có thành công hay không.
- Chất lượng mẫu tham chiếu là yếu tố quyết định tính bền lâu của đặc điểm sinh trắc

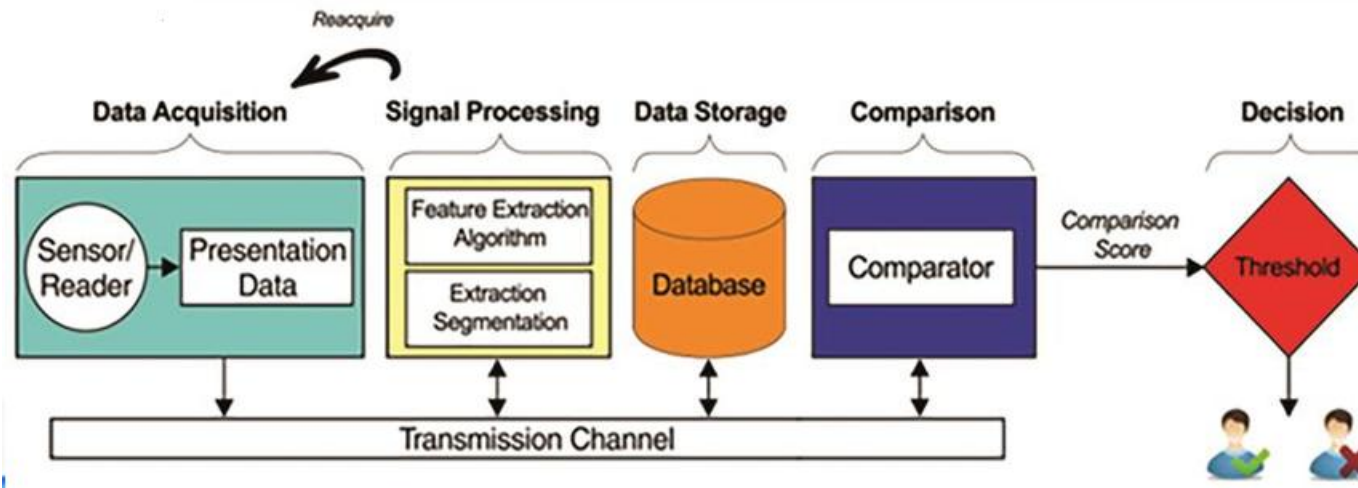
❑ Nhận dạng (Recognition): gồm các bước:

- Thu nhận dữ liệu sinh trắc (Data Acquisition),
- Trích xuất đặc trưng (Signal Processing),
- Đối sánh với mẫu tham chiếu (Comparison) và
- Ra quyết định (Decision).

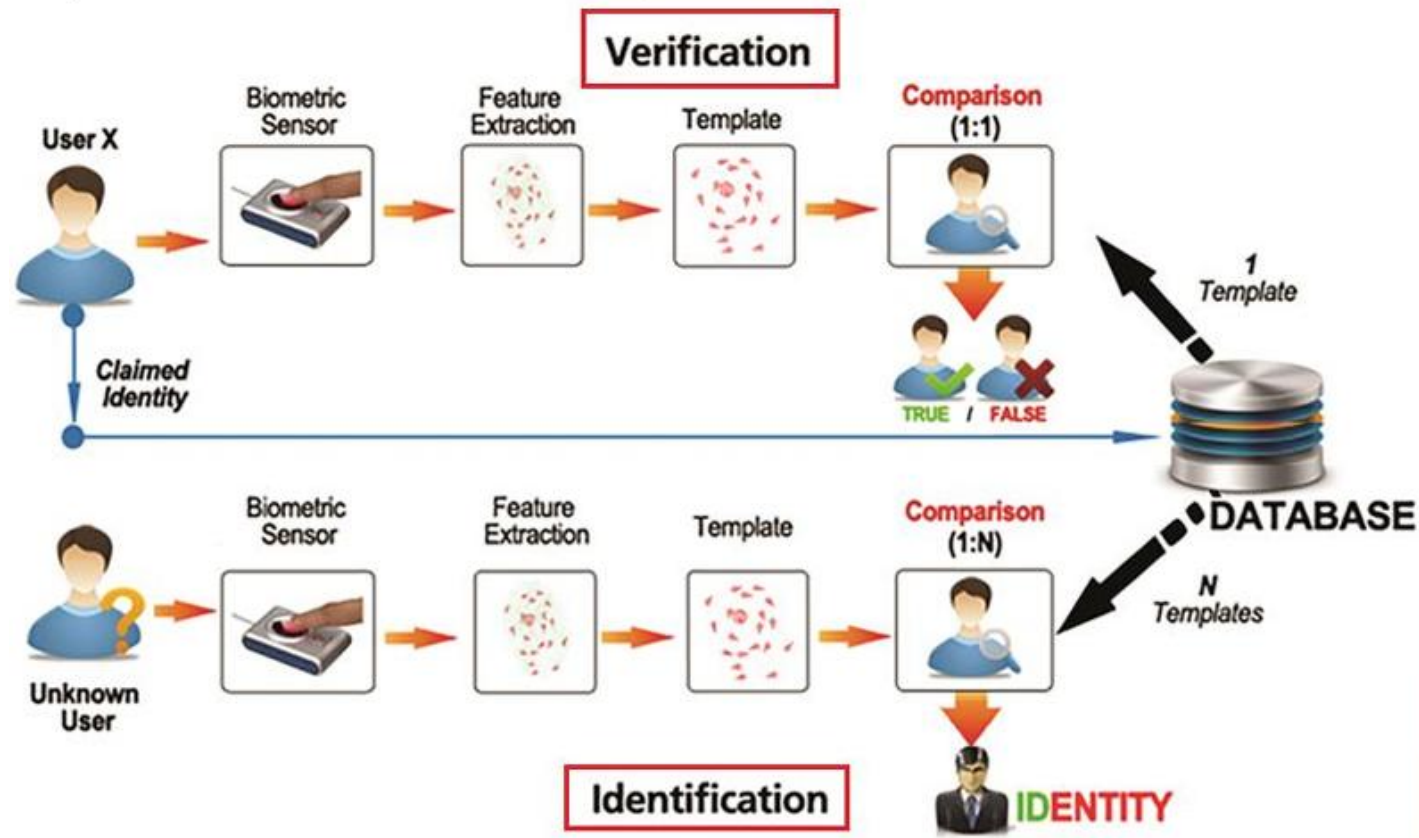
Đăng ký (Enrollment)



Nhận dạng (Recognition)

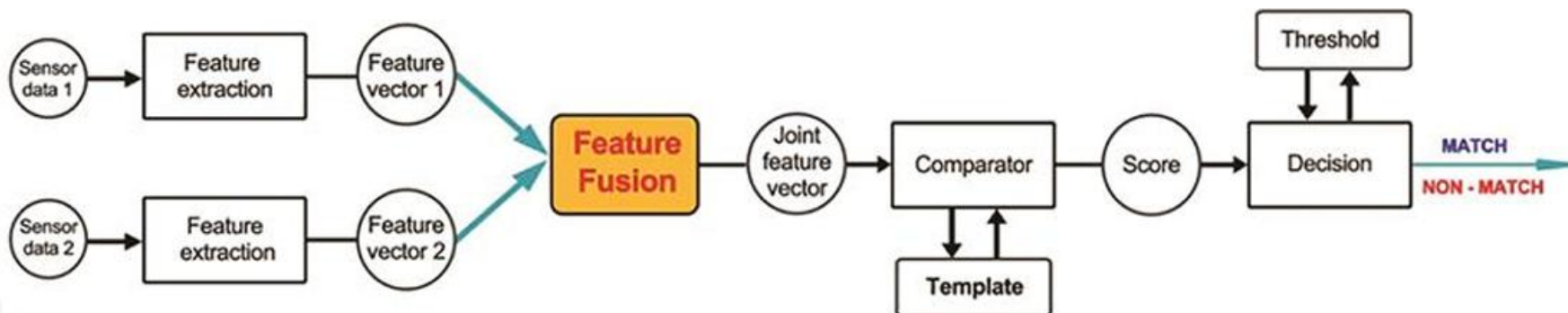


Tùy thuộc vào hệ thống định danh (Identification) hay xác minh (Verification), thì bước đối sánh (Comparison) với mẫu tham chiếu có sự thay đổi



Kết hợp các đặc trưng (Feature Fusion) khác nhau để tạo ra một tập hợp đặc trưng mới.

- Thực hiện trích xuất bằng nhiều cảm biến với người dùng.
- Khi các vector đặc trưng là đồng nhất, chẳng hạn như nhiều hình ảnh vân tay, giá trị trung bình có trọng số của các đặc trưng riêng lẻ có thể được tính toán tạo ra một vector đặc trưng (Feature vector) duy nhất.



- Ưu điểm: hiệu suất nhận dạng vượt trội so với hệ thống xác thực sinh trắc học đơn nhân tố
- Hạn chế: Chi phí cao, xử lý lâu

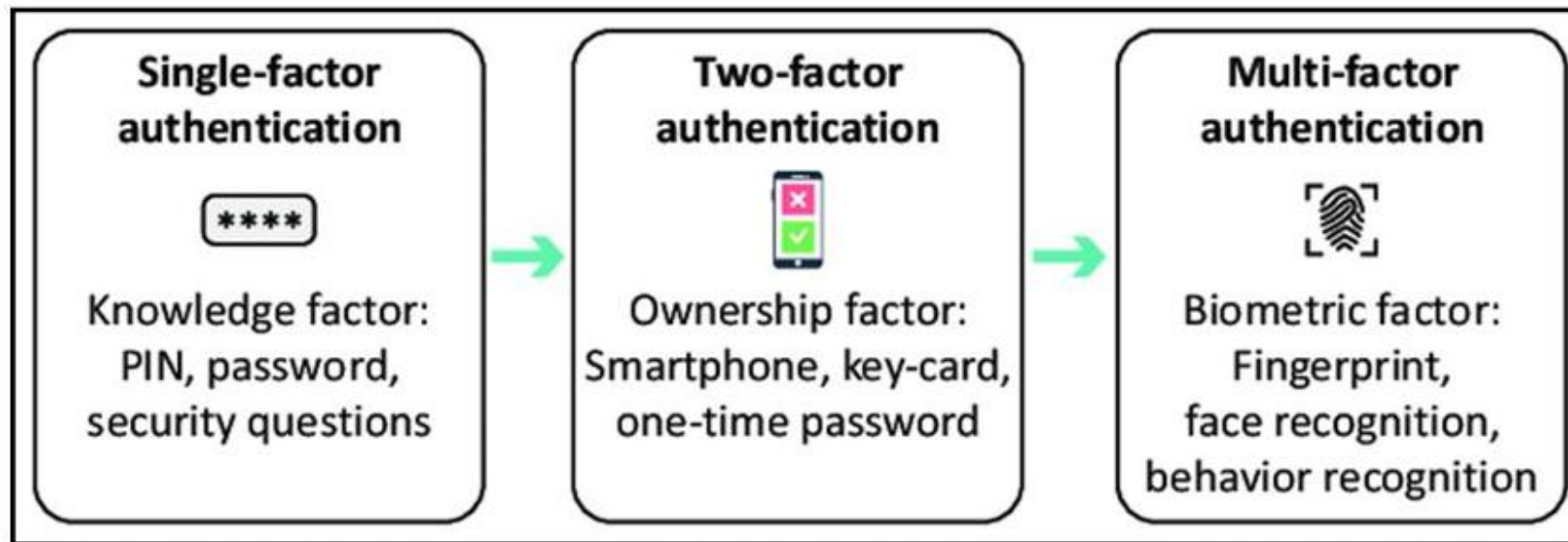
❑ **Xác thực đa yếu tố (multi-factor authentication, hay MFA):** yêu cầu ít nhất hai yếu tố xác thực trước khi cấp quyền truy cập vào tài khoản trực tuyến hoặc các ứng dụng và dịch vụ tăng cường bảo mật của bất kỳ tổ chức nào, giảm tỷ lệ tấn công mạng

❑ **Yếu tố xác thực:** Yếu tố xác minh đầu tiên là thứ bạn biết, như tên người dùng và mật khẩu hoặc mã PIN.

- Phần cứng: điện thoại di động, USB hoặc thẻ khóa để xác minh danh tính người dùng.
- Sinh trắc học: gồm dấu vân tay và quét mống mắt, giọng nói cũng có thể được sử dụng cho những mục đích này.



- ❑ Xác thực 1 yếu tố
- ❑ Xác thực 2 yếu tố (2FA – Two-factor authentication)
- ❑ Xác thực đa yếu tố (MFA- Multi-factor authentication)



- ❑ **Đăng ký:** Người dùng tạo tài khoản bao gồm tên người dùng và mật khẩu. liên kết tài khoản của mình với điện thoại di động hoặc chuỗi khóa phần cứng vật lý, địa chỉ email, số điện thoại di động hoặc mã của ứng dụng trình xác thực.
- ❑ **Xác thực:** Khi một người dùng có MFA được kích hoạt đăng nhập vào một trang web, họ sẽ được nhắc nhập tên người dùng và mật khẩu và phản hồi xác thực từ thiết bị MFA của họ. Nếu xác minh được mật khẩu, hệ thống sẽ kết nối tới các đối tượng: một mã số đến thiết bị phần cứng hoặc gửi mã thông qua tin nhắn SMS đến thiết bị di động của người dùng.
- ❑ **Phản hồi:** Người dùng hoàn tất quy trình xác thực bằng cách xác minh các đối tượng khác: nhập mã vừa nhận được hoặc nhấn nút trên thiết bị phần cứng.

- ❑ Giảm rủi ro từ mật khẩu bị xâm phạm và yếu: các hành vi đánh cắp hoặc lừa đảo một mật khẩu yếu sẽ gặp phải những trở ngại trong giai đoạn thứ hai của quá trình xác thực. Ngăn chặn các mối đe dọa mật khẩu đang phát triển như keylogger, lừa đảo và tấn công.
- ❑ Tăng cường an ninh: MFA cung cấp cho mỗi người dùng khả năng thực thi các yếu tố bổ sung để xác thực, thúc đẩy một môi trường an toàn cho tất cả người dùng
- ❑ Khả năng tương thích với đăng nhập một lần (SSO): SSO cho phép dùng một mật khẩu chung duy nhất cho tất cả các tài khoản và hệ thống. Sự kết hợp của SSO và MFA giúp loại bỏ nhu cầu về việc phải tạo nhiều mật khẩu, giải phóng tài nguyên, đồng thời hợp lý hóa và cải thiện trải nghiệm người dùng.
- ❑ Giúp đáp ứng việc tuân thủ quy định: các công ty đều tuân thủ các quy định về bảo mật

- ❑ **Xác thực từ xa:** Sự phổ biến của các thiết bị kết nối internet, biện pháp bảo vệ cho phép người dùng được xác minh để truy cập an toàn và bảo mật từ mọi nơi, mọi lúc, từ mọi thiết bị
- ❑ **Thực hiện thông qua nhiều phương pháp:**
 - xác thực hai yếu tố,
 - xác thực sinh trắc học
 - chứng chỉ kỹ thuật số
 -
- ❑ **Yêu cầu:** Cần đảm bảo bí mật thông tin xác thực khi truyền qua mạng. Tránh tấn công MITM => Các giao thức xác thực qua mạng

- ❑ Kerberos: (được MIT công bố) được sử dụng để xác thực máy khách/máy chủ trong mạng sử dụng khóa mật mã. được thiết kế để thực hiện xác thực mạnh mẽ trong khi báo cáo cho các ứng dụng. được sử dụng trong nhiều giao thức mạng và dịch vụ mạng.
- ❑ LDAP(Lightweight Directory Access Protocol)sử dụng cho các dịch vụ thư mục và xác thực. cho phép các tổ chức tập trung thông tin tài khoản người dùng và quy trình xác thực. LDAP lý tưởng cho các tổ chức lớn trong quản lý tài khoản người dùng và quy trình xác thực

- ❑ SAML(Security Assertion Markup Language) được sử dụng để xác thực đăng nhập một lần (SSO) cho phép liên lạc an toàn giữa nhà cung cấp danh tính và nhà cung cấp dịch vụ. Là giải pháp tốt nhất cho các tổ chức muốn cung cấp quyền truy cập liền mạch vào nhiều ứng dụng web bằng một bộ thông tin xác thực duy nhất.
- ❑ EAP(Extensible Authentication Protocol): là khung xác thực hỗ trợ nhiều phương thức xác thực khác nhau: EAP-TLS, EAP-PEAP và EAP-TTLS. Được sử dụng để xác thực Wi-Fi và VPN, đồng thời phù hợp với các tình huống truy cập không dây và từ xa.

- ❑ **RADIUS (Remote Authentication Dial-In User Service):** RADIUS được sử dụng để quản lý truy cập mạng từ xa. Khi người dùng yêu cầu quyền truy cập vào tài nguyên mạng, máy chủ RADIUS mã hóa thông tin xác thực được người dùng nhập. Sau đó, thông tin đăng nhập của người dùng được ánh xạ thông qua CSDL cục bộ và cung cấp quyền truy cập, chẳng hạn như Wi-Fi hoặc VPN, mạng công ty và ISP.

Các phương pháp xác thực mạng khác nhau về độ phức tạp và mức độ bảo mật

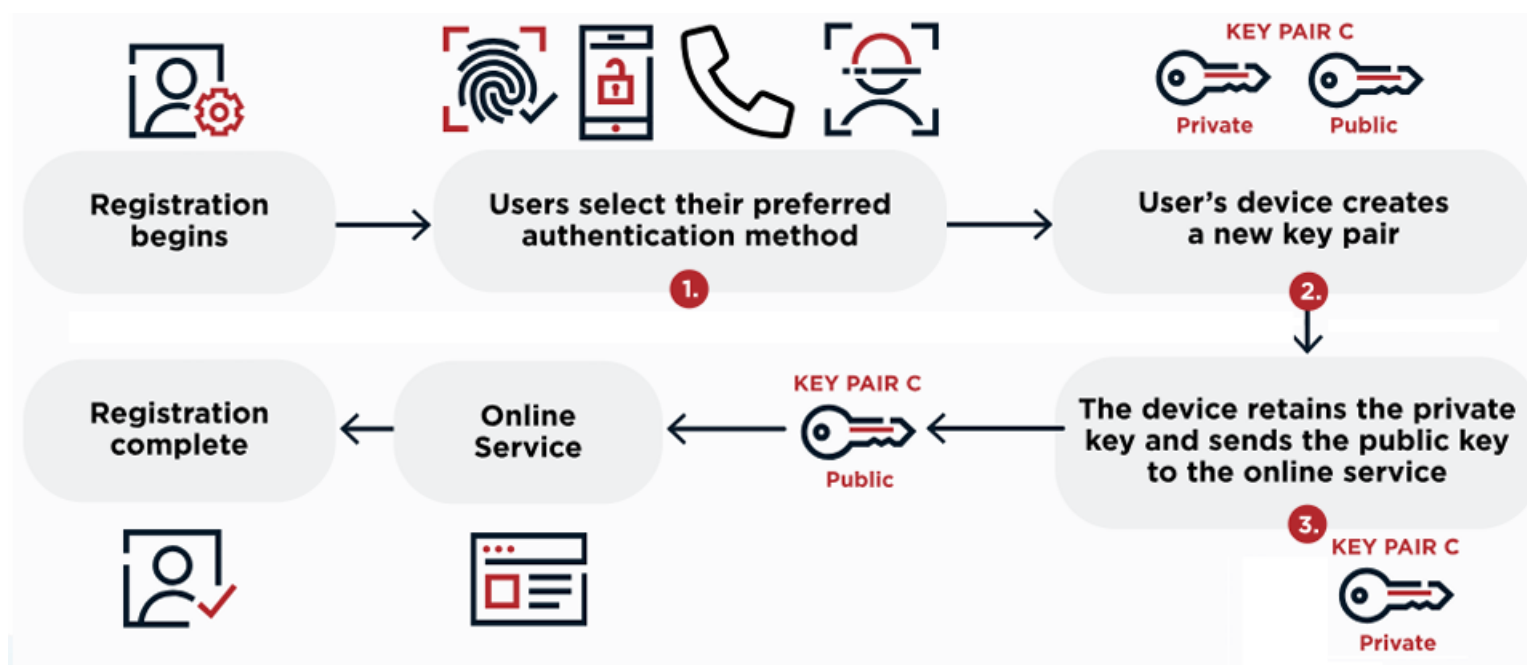
- ☐ Username and password
- ☐ Multi-factor authentication (MFA)
- ☐ Certificate-based authentication
- ☐ Biometric authentication
- ☐ Token-based authentication
- ☐ Single Sign-On (SSO)

Xác thực không mật khẩu (Passwordless authentication)

- ☐ Vào cuối những năm 2010, xác thực không mật khẩu đã bắt đầu đầu được biết đến.
- ☐ Đầu thập niên 2020, công nghệ này mới được ứng dụng cho nhiều nền tảng.
- ☐ Không yêu cầu người dùng nhập mật khẩu để đăng nhập.
- ☐ Cải thiện hoặc điều chỉnh các phương pháp xác thực hiện tại.
- ☐ Xác thực mạnh mẽ và không bao giờ chia sẻ bất kỳ bí mật nào

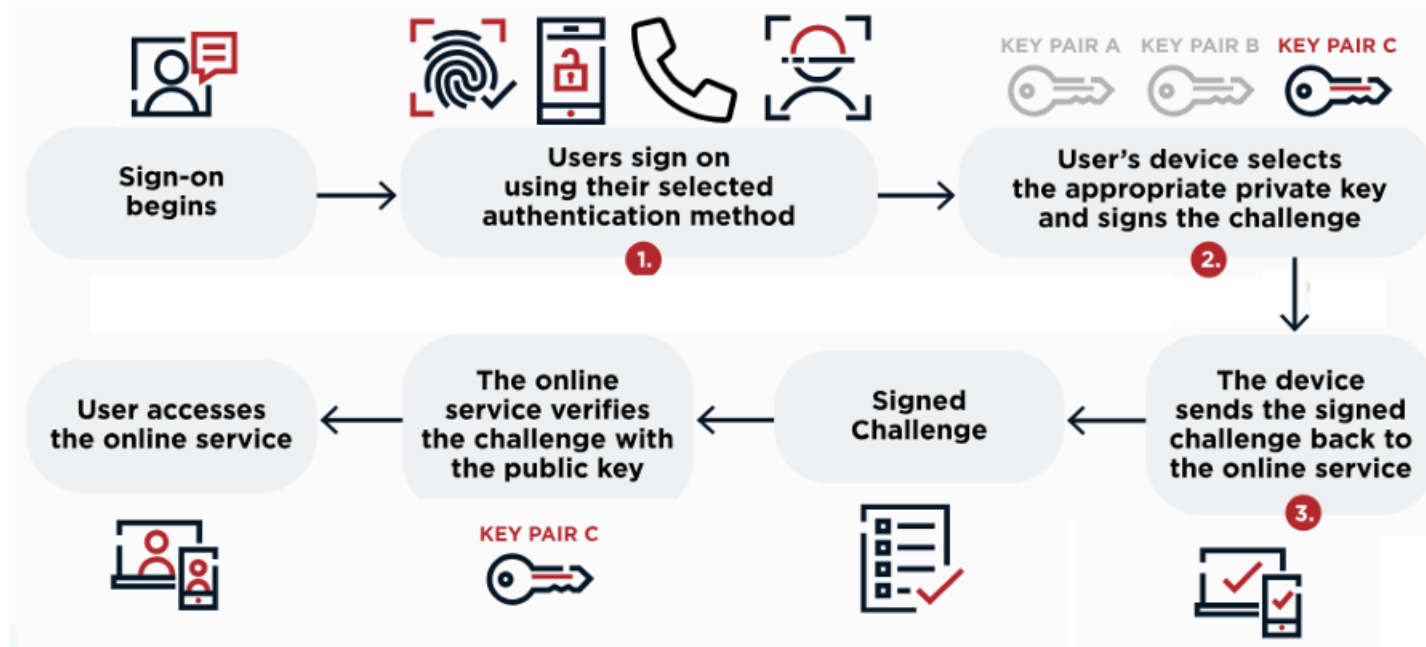
- ❑ FIDO2 là bộ tiêu chuẩn cho xác thực mạnh (strong authentication) không cần mật khẩu (passwordless) và/hoặc thay thế lớp mật khẩu trong MFA, dựa trên khóa công khai (public-key cryptography).
- ❑ Gồm 2 phần chính:
 - WebAuthn (W3C): API trong trình duyệt/website để gọi “authenticator”.
 - CTAP2 (FIDO Alliance): giao thức để trình duyệt/OS nói chuyện với thiết bị xác thực (USB/NFC/BLE hoặc built-in như biometrics).

Đăng ký



Một cặp khóa được tạo khi người dùng đăng ký tài khoản mới. Người dùng giữ khóa riêng và nó không bao giờ rời khỏi thiết bị của họ. Bất cứ ai cũng có thể giữ khóa công khai tương ứng.

Đăng nhập



Chú ý, khóa riêng của người dùng là vùng đệm giữa họ và nhà cung cấp. Sinh trắc học và khóa riêng của họ không bao giờ rời khỏi thiết bị của họ.

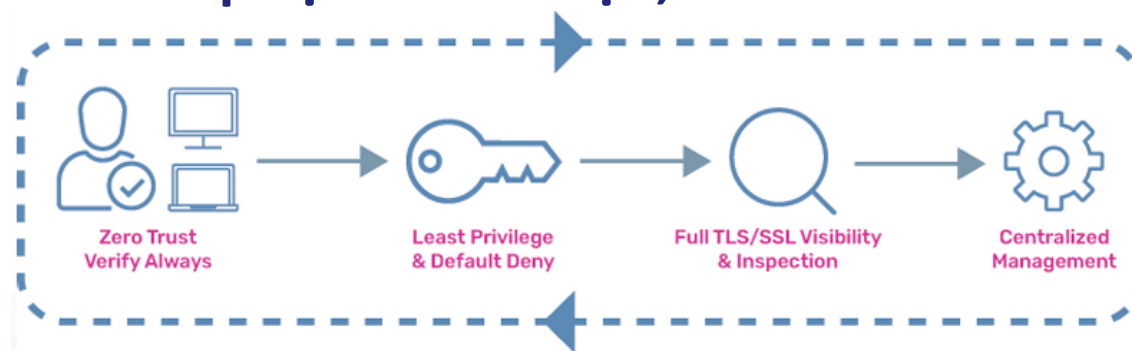


- ☐ **Email**: Người dùng sẽ nhận được một email có liên kết khi họ cố gắng đăng nhập
- ☐ **OAuth**: cho phép uỷ quyền truy cập, thường được dùng như cách để người dùng cấp quyền cho một trang web
- ☐ **Token/SSO**: cho phép dùng một mã Token chung duy nhất cho tất cả các tài khoản
- ☐ **Sinh trắc học**: người dùng cung cấp dữ liệu sinh trắc học của họ khi họ đăng nhập
- ☐ **Chứng chỉ số**: được cấp bởi bên thứ 3 đáng tin cậy

- ❑ **Bảo vệ:** Mỗi Website/tài khoản sẽ có mã xác thực FIDO2 riêng, không trùng lặp nên có thể giảm nguy cơ bị tấn công khi thông tin của 1 trong các website/tài khoản bị lộ.
- ❑ **Sự tiện lợi:** Người dùng có thể mở khóa thông tin đăng nhập bằng cách sử dụng các phương pháp như: vân tay, khuôn mặt,... hoặc sử dụng các khóa bảo mật FIDO2 để đăng nhập.

- ❑ **Sự riêng tư:** Mã thông tin xác thực FIDO2 được tạo ra riêng biệt nên người dùng không bị theo dõi hành vi trên các trang web khác nhau. Thông tin đăng nhập, dữ liệu sinh trắc học (vân tay, khuôn mặt, v.v.) không được lưu trữ trên máy chủ, đảm bảo tính riêng tư cao hơn, giảm rủi ro từ việc máy chủ bị tấn công và dữ liệu xác thực bị đánh cắp.
- ❑ **Khả năng mở rộng:** FIDO2 được hỗ trợ trên nhiều trình duyệt web và các nền tảng phổ biến trên thế giới hiện nay, giúp người dùng dễ dàng triển khai trên hàng tỷ thiết bị, ứng dụng khác nhau.

- ❑ Zero-trust: “không bao giờ tin cậy, luôn xác minh”, người dùng và thiết bị không được tin cậy theo mặc định, ngay cả khi chúng được kết nối với mạng được cấp phép như mạng LAN và ngay cả khi chúng đã được xác minh trước đó.
- ❑ Khung bảo mật yêu cầu tất cả người dùng, dù ở trong hay ngoài mạng của tổ chức, phải được xác thực, ủy quyền và xác thực liên tục về cấu hình và trạng thái bảo mật trước khi được cấp hoặc giữ quyền truy cập vào ứng dụng và dữ liệu. được gọi là bảo mật không vành đai, mô tả cách tiếp cận chiến lược, thiết kế và triển khai hệ thống CNTT



Attacks	Authenticators	Examples	Typical Defenses
Client attack	Password	Guessing, exhaustive search	Large entropy; limited attempts
	Token	Exhaustive search	Large entropy; limited attempts; theft of object requires presence
	Biometric	False match	Large entropy; limited attempts
Host attack	Password	Plaintext theft, dictionary/exhaustive search	Hashing; large entropy; protection of password database
	Token	Passcode theft	Same as password; 1-time passcode
	Biometric	Template theft	Capture device authentication; challenge response

Eavesdropping, theft, and copying	Password	“Shoulder surfing”	User diligence to keep secret; administrator diligence to quickly revoke compromised passwords; multifactor authentication
	Token	Theft, counterfeiting hardware	Multifactor authentication; tamper resistant/evident token
	Biometric	Copying (spoofing) biometric	Copy detection at capture device and capture device authentication
Replay	Password	Replay stolen password response	Challenge-response protocol
	Token	Replay stolen passcode response	Challenge-response protocol; 1-time passcode
	Biometric	Replay stolen biometric template response	Copy detection at capture device and capture device authentication via challenge-response protocol
Trojan horse	Password, token, biometric	Installation of rogue client or capture device	Authentication of client or capture device within trusted security perimeter
Denial of service	Password, token, biometric	Lockout by multiple failed authentications	Multifactor with token

- ❑ Nguyên tắc xác thực người dùng điện tử
- ❑ Các phương pháp xác thực: mật khẩu, Token, sinh trắc học, đa yếu tố (MFA), người dùng từ xa, không mật khẩu.
- ❑ Các vấn đề bảo mật để xác thực người dùng



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 3

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn